

DNS 安全发展历程与现状

段俊宇

南开大学 密码与网络空间安全学院 信息安全、法学双学位班

摘 要 域名系统（DNS）作为互联网关键基础设施，其安全性直接影响网络服务的可靠运行。本文系统梳理了 DNS 安全技术的发展历程，从早期无安全机制、DNS 缓存投毒攻击暴露阶段，到 DNSSEC 提出与部署阶段，再到现代基于加密和机器学习的新型防护阶段。通过对比分析各阶段关键技术的原理、优势与局限性，揭示了 DNS 安全从“无认证”向“端到端加密”演进的必然趋势。本文还分析了当前 DNS 安全面临的新挑战，包括加密 DNS 下的内容监管困境、侧信道攻击风险以及量子计算对现有密码体系的威胁，并展望了后量子 DNSSEC 与区块链域名系统等未来方向。

关键词 域名系统；DNS 安全；DNSSEC；加密 DNS；缓存投毒

The Development History and Current Status of DNS Security

Duan Junyu

Nankai University

Abstract The Domain Name System (DNS), as a critical infrastructure of the Internet, directly affects the reliable operation of network services through its security posture. This paper systematically reviews the development history of DNS security technologies, covering the early era with no built-in security mechanisms, the emergence of DNS cache poisoning attacks, the proposal and gradual deployment of DNSSEC, and the modern phase characterized by encryption-based and machine-learning-enhanced protection. Through comparative analysis of the principles, advantages, and limitations of key technologies in each stage, this paper reveals the inevitable evolution of DNS security from "no authentication" towards "end-to-end encryption". This paper also analyzes emerging challenges to DNS security, including content supervision difficulties under encrypted DNS, side-channel attack risks, and the threat of quantum computing to existing cryptographic schemes. Future research directions such as post-quantum DNSSEC and blockchain-based domain name systems are also discussed.

Key words Domain Name System; DNS security; DNSSEC; encrypted DNS; cache poisoning

1 引言

域名系统（Domain Name System, DNS）诞生于 1983 年，其核心功能是将易于记忆的域名转换为网络设备可识别的 IP 地址¹²。经过四十余年的发展，DNS 已演进为全球分布式、层次化、高容错的关键网络基础设施。然而，DNS 在设计之初主要关注可扩展性、容错性和查询效率，并未系

统性地考虑安全问题。正如 Schmid 指出的：“当 DNS 被创建时，没有人预料到它会成为数字经济的基础和网络犯罪的主要目标。”³早在 1993 年，RFC 1536 就指出了 DNS 实现中的常见错误和安全缺陷⁴，这一设计缺陷导致 DNS 成为网络攻击的高频目标。

2008 年，Dan Kaminsky 发布了著名的 DNS 缓存投毒攻击，可在较短时间内污染任意域名记录，影响范围覆盖全球绝大多数 DNS 解析器⁵。此外，DNS 还被滥用于数据外泄、

恶意软件命令与控制通信等场景。

面对持续演化的威胁, DNS 安全技术经历了从无到有、从被动防御到主动加密的深刻变革。1995 年互联网工程任务组启动了 DNSSEC (DNS Security Extensions) 标准化工作, 试图通过数字签名为 DNS 响应提供完整性校验和来源认证⁶。然而, DNSSEC 因部署复杂度高、密钥管理困难、响应报文膨胀等问题, 至今仍未实现全面普及。2018 年, DoH 正式成为 RFC 标准, 通过将 DNS 查询封装在 HTTPS 隧道中, 有效抵御了窃听和中间人篡改⁷。近年来, 基于机器学习的异常检测在 DNS 隧道检测方面取得了显著成果, 后量子密码学在 DNSSEC 中的应用也逐渐成为研究热点。

本文的结构安排如下: 第 2 节介绍 DNS 基础架构与安全威胁模型, 第 3 节按阶段详细梳理 DNS 安全技术发展历程, 第 4 节总结现状并对比主流方案, 第 5 节分析未来挑战与研究方向, 第 6 节为结束语, 第 7 节为人工智能使用说明。

2 DNS 基础与安全威胁

2.1 DNS 体系架构

DNS 采用层次化树状命名空间, 根域、顶级域、二级域及子域逐级授权。完整的域名解析过程从根服务器开始, 经顶级域服务器、权威域名服务器, 最终返回 IP 地址¹²。整个架构包含以下核心组件:

- (1) 存根解析器 (Stub Resolver): 通常集成在操作系统或应用程序中, 负责将应用程序的域名查询请求发送给递归解析器, 并接收返回结果。
- (2) 递归解析器 (Recursive Resolver): 通常由互联网服务提供商或公共 DNS 服务商运营。它代替客户端完成整个递归查询过程, 并将结果缓存以供后续查询使用。
- (3) 权威域名服务器 (Authoritative Name Server): 负责管理特定域名的资源记录, 包括 A 记录 (IPv4 地址)、AAAA 记录 (IPv6 地址)、MX 记录 (邮件交换器)、CNAME 记录 (别名) 等。
- (4) 根服务器与顶级域服务器: 根服务器全球共 13 组, 管理根区文件; 顶级域服务器管理如 .com、.org、.cn 等顶级域的域名信息。

DNS 解析过程分为两个阶段: 第一阶段是客户端与递归解析器之间的通信; 第二阶段是递归解析器与权威域名服务器之间的迭代查询。DNS 默认使用 UDP 53 端口进行查询和响应, 当响应报文超过 512 字节时自动回退到 TCP 53 端口。这一设计虽然在早期有效平衡了效率与可靠性, 但也为后续的安全问题埋下了隐患。

2.2 DNS 协议的安全缺陷

DNS 协议在设计上主要存在以下安全缺陷:

- (1) 缺乏源认证: 递归解析器无法验证收到的 DNS 响应是否确实来自声称的权威服务器, 攻击者可以伪造源 IP 地址发送虚假响应数据包。
- (2) 缺乏完整性保护: DNS 报文没有数字签名或消息认证码, 响应内容在传输过程中可被中间节点篡改而不被发现。
- (3) 缺乏机密性保护: DNS 查询和响应默认以明文形式传输, 沿途任何网络节点均可完整获知用户查询的域名。
- (4) 事务 ID 熵值不足: 传统 DNS 查询使用 16 位事务 ID 进行请求-响应匹配, 理论上只有 65536 种可能取值, 攻击者通过暴力猜测即可伪造。

2.3 安全威胁

2.3.1 数据伪造类攻击

数据伪造类攻击的核心目标是使 DNS 解析器返回错误的 IP 地址, 从而将用户流量劫持至恶意站点。

缓存投毒攻击 (Cache Poisoning) 是最典型的代表。2008 年, Dan Kaminsky 发现了 DNS 协议的一个严重漏洞, 攻击者无需嗅探网络流量, 只需向目标递归解析器发送大量伪造响应, 即可在数秒至数分钟内污染任意域名的缓存记录⁴。攻击成功后, 用户访问合法网站时将被重定向到攻击者控制的钓鱼网站, 造成账号密码泄露、财产损失等严重后果。

2.3.2 拒绝服务攻击

DNS 在拒绝服务攻击中既可以是被攻击目标, 也可以被滥用作为攻击放大器。

DNS 放大攻击 (DNS Amplification Attack) 是一种典型的反射型 DDoS 攻击。攻击者将伪造源 IP 的短查询发送到开放的 DNS 递归解析器, 解析器向受害者返回长达数千字节的响应报文。通过控制请求报文与响应报文的大小比例 (放大倍数可达 30~70 倍), 攻击者仅使用相对较小的攻击流量就可以实现巨大的打击效果。

NXDOMAIN 泛洪攻击是一种针对权威服务器的资源耗尽攻击。攻击者利用僵尸网络向目标域名的权威服务器发送大量针对随机生成、不存在的子域名的查询请求。由于每个查询的子域名都不同, 递归解析器无法从缓存中返回结果, 必须不断向权威服务器转发这些无效查询。权威服务器被迫反复执行数据库查找, 每次查找后返回 NXDOMAIN 响应, 从而消耗大量计算资源, 最终导致无法响应合法用户的正常解析请求。

2.3.3 隐私泄露威胁

DNS 查询默认以明文 UDP 传输, 沿途网络节点均可完

整获知用户的域名访问记录。这意味着互联网服务提供商可以记录用户访问过的所有网站，公共 Wi-Fi 热点的运营者可以分析用户的 DNS 流量，甚至中间网络设备也可以实时监控用户的域名查询。

研究表明，即使只分析 DNS 查询流量的元数据，也可以有效识别用户的网页浏览行为。这种隐私泄露风险在 2013 年斯诺登事件后被广泛关注，直接推动了加密 DNS 协议的发展。

2.3.4 域名滥用与恶意注册

攻击者还可以利用 DNS 协议本身作为隐蔽通信的通道或进行欺诈活动。

DNS 隧道利用 DNS 协议允许查询包含任意字符串的特点，将非 DNS 数据编码后封装在 DNS 查询或响应中。由于绝大多数防火墙允许 DNS 流量通过，DNS 隧道成为数据外泄、绕过网络审查、恶意软件命令与控制通信的常用手段。

此外，在域名抢注与同形异义字攻击中，攻击者通过构造与知名域名在视觉上无法区分的相似域名，用于钓鱼、散布恶意软件或点击欺诈。

3 DNS 安全技术发展历程

3.1 无安全机制时期（1983-1993）

DNS 协议最初的规范完全没有涉及认证、机密性或完整性保护¹²。设计者假定网络环境相对可信，主要关注分布式数据库的副本一致性和查询效率。

这一阶段中，DNS 报文不包含任何密码学字段，使用明文传输；递归解析器无条件信任任何收到的响应，不进行额外的校验。此外，各 DNS 实现之间存在大量兼容性问题。

1993 年，RFC 1536 专门指出了 DNS 实现中的常见错误和安全问题，包括响应验证不严格、缓存管理不当等缺陷。该文档表明，早在 DNS 大规模普及之前，研究者已经意识到其安全设计存在问题。但由于当时互联网规模较小，且用户主要为科研教育机构，大规模攻击并未发生，安全问题未被优先解决。

3.2 投毒攻击暴露与被动防御（1993-2008）

1990 年代中期，随着互联网的商业化，DNS 开始承载电子商务、电子邮件等敏感应用，自此攻击动机开始出现。

在 1993 年至 1997 年间，研究者首次公开演示了 DNS 缓存投毒攻击，证明攻击者可以在实验室环境下成功污染解析器缓存，由此引发了世界范围内的关注。1995 年，Eastlake 和 Kaufman 发布了首个 DNSSEC 草案，提出了通过数字签名保护 DNS 数据的思路⁵。但由于标准化过程中的争议和部署复杂性问题，DNSSEC 的研究进展缓慢。

2008 年，Dan Kaminsky 在 Black Hat 会议上发布了轰动性的 DNS 漏洞⁴。该攻击的关键在于，攻击者无需嗅探网络流量，只需向目标解析器发送大量伪造响应即可在较短时间内污染任意域名记录。具体而言，攻击者先向解析器查询一个不存在的子域名，诱使解析器向权威服务器发起查询；与此同时，攻击者批量发送伪造的 NS 记录响应，试图将目标域名的权威服务器指向攻击者控制的 IP。一旦成功，攻击者即可完全控制该域名的所有后续解析。

Kaminsky 攻击公布后，全球 DNS 社区紧急响应。微软、思科、ISC 等主要厂商在数周内发布了补丁，采取了端口随机化、查询 ID 随机化等被动加固措施。这些方法没有改变协议本身，而是通过增加攻击者的猜测难度来缓解投毒风险。然而，这些措施属于临时防御措施，无法彻底阻止内网嗅探或生日攻击。

3.3 DNSSEC 的标准化与部署尝试（1995 年至今）

DNSSEC 经历了漫长的标准化过程，最终在 2005 年，RFC 4033、4034、4035 正式确立了 DNSSEC 的协议规范。DNSSEC 的核心机制包括⁵：

- (1) 数字签名：每个 DNS 资源记录集附带一个 RRSIG 记录，用于包含该记录集的数字签名。签名由区域私钥生成，客户端使用区域公钥验证。
- (2) DNSKEY 记录：存储区域公钥，用于验证 RRSIG 签名。
- (3) DS 记录：实现子域与父域之间的信任委派。子域将其公钥的哈希值提交给父域，父域将该 DS 记录发布在其区域文件中，从而建立从根密钥到任意子域的信任链。
- (4) NSEC/NSEC3 记录。支持已认证的拒绝存在，即证明某个域名确实不存在于区域中，同时防止区域遍历攻击。

理论上，如果客户端信任根锚点，并沿着信任链逐级验证签名，即可保证收到的响应未被篡改且来自域名的合法管理者。

然而，DNSSEC 在实际部署中仍然面临部署复杂度高、响应报文膨胀等障碍。

在部署过程中，启用 DNSSEC 需要区域管理员生成并管理密钥对、定期轮转密钥，还需要维护签名有效期。对于大型区域，签名计算和响应报文的生成需要消耗大量的计算资源。其次，DNSSEC 响应报文比明文响应报文大 3~5 倍。这导致 UDP 分片概率增加，迫使解析器频繁回退到 TCP 模式，增加延迟和服务器负载。

对于客户端来说，部署 DNSSEC 需要内置根密钥锚点。根密钥轮转时，所有 DNSSEC 验证客户端必须同步更新，否则会将所有签名验证为失败，而这一更新过程的协调难度

极高。

除上述问题外，DNSSEC 还存在验收风险。大型递归服务商担心开启 DNSSEC 验证后，若某个域名的签名配置错误或过期，将导致大量用户无法访问该域名，从而引发用户投诉。这种商业层面的考量，使得许多服务商迟迟不肯开启验证，增加了 DNSSEC 的部署难度。

Chung 等人的大规模测量研究揭示了 DNSSEC 管理的普遍问题：研究发现 31%支持 DNSSEC 的域名未能发布验证所需的所有相关记录，39%的域名使用的密钥签名强度不足，尽管 82%的解析器请求 DNSSEC 记录，但只有 12%实际尝试验证它们⁸。这一数据表明，尽管 DNSSEC 标准化已近二十年，其实际效用因部署碎片化而大打折扣。

3.4 加密 DNS 与现代防护（2014 年至今）

2013 年斯诺登事件曝光了大规模网络监听的存在，使得 DNS 隐私保护成为新的关注焦点。传统 DNS 威胁模型中，缓存投毒和篡改被视为最严重威胁，但人们逐渐意识到明文 DNS 查询本身会泄露用户的访问历史，这一认知推动了加密 DNS 协议的快速发展。

DoT 的出现，定义了 DNS 客户端与递归解析器之间建立 TLS 隧道的规范。它使用专用的 853 端口，旨在提升 DNS 查询的隐私性和安全性。相较于 DoT，2018 年正式发布的 DoH 更加重要⁷。它将 DNS 查询封装在 HTTP/2 或 HTTP/3 的 HTTPS 请求中，复用 HTTPS 的 443 端口，与普通 Web 流量难以区分，大幅提高了防火墙旁路能力和抗审查性。主流浏览器均已内置 DoH 功能，用户在浏览器设置中可启用“使用安全 DNS”选项。

除此之外，DNS 加密协议还有 DNSCrypt。它是由 OpenDNS 于 2011 年提出的非 IETF 标准，采用客户端-服务器公钥加密模式。由于缺乏标准化组织推动和浏览器生态支持，DNSCrypt 的普及程度远低于 DoH/DoT，但在部分注重隐私的用户群体中仍有使用。

在加密 DNS 协议兴起的同时，基于机器学习的异常检测系统也在不断发展，如今已经被应用于 DNS 服务器侧。传统基于规则或签名的检测方法难以应对快速变异的 DNS 隧道工具和 DGA 域名，不能及时检测到 DNS 异常。

Sa'ad 等人提出的 HERALD 框架结合了孤立森林、单类支持向量机和局部离群因子等无监督基检测器与随机森林元模型，在 CIRA-CIC-DoHBrw-2020 数据集上达到了 99.99%的准确率，推理时间仅为 2.2 毫秒。该框架在跨数据集评估中表现出优越的泛化能力，性能下降仅为 2-4%，远优于纯监督模型的 5-8%⁹。此外，基于无监督机器学习的地理分析方法也被用于 DNS 威胁检测，K-means 聚类实现了 0.985 的轮廓系数，基于熵的异常检测准确率达到 92.3%¹⁰。

4 现状分析与主流方案对比

4.1 技术部署现状

综合各研究机构和行业报告的分析，当前 DNS 安全格局可从 DNSSEC、加密 DNS 和机器学习检测三方面进行分析。

在 DNSSEC 方面，如第 3.3 节所述，Chung 等人的测量研究发现，尽管绝大多数的解析器请求 DNSSEC 记录，但只有少部分实际尝试验证它们。全球范围内，根域和绝大多数顶级域已完成 DNSSEC 签名，但在递归解析器侧启用签名验证的比例仍然偏低。这意味着“签名已发布，但多数用户并未验证”的情况普遍存在。

在加密 DNS 方面，DoH 和 DoT 的使用率持续增长。主流公共 DNS 服务商（Cloudflare 1.1.1.1、Google Public DNS 8.8.8.8、Quad9 9.9.9.9）均已支持加密 DNS 协议。主要操作系统（Windows、macOS、iOS、Android）和浏览器（Chrome、Firefox、Edge）也陆续提供了加密 DNS 的配置选项。然而，加密 DNS 的普及也引发了企业网络管理、内容审查、网络安全监控等方面的争议。

在机器学习检测方面，学术研究中已报道了多种基于机器学习的 DNS 异常检测方法。HERALD 等混合集成方法在加密 DNS 流量检测中表现出接近完美的性能指标⁹，基于地理分析和 K-means 聚类的方法也取得了 92.3%的检测准确率¹⁰。然而，这些方法在真实网络环境中的长期稳定性、对抗抗攻击能力仍需进一步验证。

4.2 主流安全方案对比

表 1 对比了 DNSSEC、DoH/DoT 以及基于机器学习的异常检测方案的特性。

技术方案	主要解决威胁	设计目标	部署位置	典型性能及局限性
DNSSEC	缓存投毒、响应篡改	数据完整性认证、来源认证	权威服务器、递归解析器	理论安全性高，但递归侧验证启用率偏低；响应报文膨胀 3-5 倍。
DoH/DoT	窃听、中间人篡改、流量分析	传输机密性	客户端、递归解析器	有效防止窃听，但增加 TLS 握手延迟；与 DNSSEC 可组合使用。
机器学习	DNS 隧道	威胁	递归	可检测未知模

异常检测	道、放 DGA、放大攻击	实时 检测与阻 断	解析 器旁路、网 络边界	式攻击，但对 抗样本敏感；需持续训 练更新。
------	-----------------	-----------------	--------------------	------------------------------

从表中可见，DNSSEC 提供数据完整性认证和来源认证，加密 DNS 提供传输机密性，两者并不互斥，理想方案是同时部署。Jahromi 等人对 14 种安全 DNS 方案的评估表明，没有单一方案能在整个解析路径上提供理想的保护，各方案针对解析过程的不同阶段，具有互补性。^[1]

4.3 现存主要问题

尽管 DNS 安全技术在不断进步，但实际应用中仍面临不少的挑战。

- (1) 碎片化部署。DNSSEC 在递归解析器侧的验证启用率过低，导致大量已签名的域名无法被客户端有效验证。加密 DNS 在不同操作系统、浏览器、应用程序中的配置方式不统一，用户体验不一致。
- (2) 安全与监管的冲突。DoH 使企业网络管理员难以审计内部 DNS 请求，传统依赖 DNS 拦截的恶意软件防护策略失效。同时，恶意软件也可利用加密 DNS 隐蔽地外传数据而不被检测。
- (3) 侧信道攻击。即使采用加密 DNS，攻击者仍可通过分析加密流量的包大小、时序、方向等侧信道特征推断用户访问的网站。
- (4) 后量子威胁。当前 DNSSEC 和 DoH/DoT 所依赖的公钥密码体制（RSA、椭圆曲线密码、Diffie-Hellman 密钥交换）在量子计算机面前是脆弱的。一旦足够强大的量子计算机问世，DNSSEC 的数字签名可被伪造，TLS 会话密钥可被恢复。

5 未来挑战与研究方向

5.1 后量子 DNSSEC

Shor 算法表明，量子计算机可在多项式时间内解决大整数分解和离散对数问题，从而破解 RSA 和椭圆曲线密码。可以预见，DNSSEC 当前广泛使用的 RSA-2048 和 ECDSA P-256 签名算法在量子计算机成熟后将完全失效。

IETF DNSOP 工作组已开始讨论后量子 DNSSEC 的标准化路线图，但实际部署仍有不小的距离。主要挑战在于如何在有限报文中容纳大体积后量子签名，以及如何在密钥轮转频率和安全性之间取得平衡。

5.2 区块链域名系统

近年来，Namecoin、Handshake、Ethereum Name Service

等项目尝试用区块链取代传统 DNS 根区管理，实现域名注册、更新、解析的去中心化。其核心理念是将域名映射关系存储在区块链的分布式账本中，由共识机制保证一致性，无需信任中心化的根管理机构。

区块链 DNS 的优势有抗审查、无单点故障、域名注册规则透明等，然而，它也面临解析延迟高、链上存储昂贵以及治理规则冲突等挑战。截至 2024 年，区块链域名的实际使用率远低于传统 DNS，更多停留在技术试验阶段。

6 结束语

DNS 安全经历了从无保护到签名认证、从明文传输到端到端加密的深刻演变，每个阶段都有标志性的攻击事件推动安全技术升级。当前，DNSSEC 提供了理论上最强的完整性认证机制，但其部署碎片化问题严重，递归侧验证启用率远未达到理想水平。加密 DNS 极大改善了用户隐私保护，却带来了网络监管、企业安全审计的新挑战。机器学习为检测 DNS 隧道、DGA 等未知威胁提供了智能化手段，但对抗机器学习又成为新的攻防战场。

展望未来，后量子密码学有望从根本上解决量子计算对 DNS 安全的威胁，但仍需要解决签名体积、验证延迟、标准兼容性等工程难题。区块链技术为去中心化域名管理提供了新思路，但距离大规模实用仍有不小的实现难度。

对于中国网络安全学术界和产业界而言，在推进国产密码算法 DNSSEC 应用、建设国家级加密 DNS 递归基础设施、制定跨境域名安全治理规则等方面，均有大量值得深入研究的课题。

7 人工智能使用说明

在本论文的编写过程中，我使用 deepseek 搜集了 DNS 安全发展历程的内容及参考文献，论文的部分内容也参考了人工智能的总结性语言。全文内容、数据及引用文献均为真实有效，不存在编造的情况。在使用人工智能的过程中，会出现编造数据、编造参考文献等情况，但是通过排查都解决了这类问题。

参 考 文 献

[1]P. V. Mockapetris. RFC1034: Domain names - concepts and facilities.
[2]P. V. Mockapetris.RFC1035: Domain names - implementation and specification.
[3]G. Schmid.Thirty Years of DNS Insecurity: Current Issues and Perspectives.
[4]Kumar A, Postel J, Neuman C, et al. RFC1536: Common DNS Implementation Errors and Suggested Fixes.
[5]Kaminsky D. It’ s the end of the cache as we know it. Black Hat, 2008.

- [6]Donald E. Eastlake 3rd and Charles W. Kaufman.Domain Name System Security Extensions.IETF Internet-Draft.
- [7]P. Hoffman, P. McManus.RFC 8484: DNS Queries over HTTPS (DoH).
- [8]Chung T, van Rijswijk-Deij R, Chandrasekaran B, et al. A longitudinal, end-to-end view of the DNSSEC ecosystem. Proceedings of the 26th USENIX Security Symposium.
- [9]Sa'ad U, Lakew D S, Dao N N, et al. HERALD: Hybrid Ensemble Approach for Robust Anomaly Detection in encrypted DNS traffic.
- [10]Seyed-Ali Sadegh-Zadeh, Mostafa Tajdini.An unsupervised machine learning approach for cyber threat detection using geographic profiling and Domain Name System data.
- [11]Jahromi, Ali Sadeghi and Abdou, AbdelRahman and van Oorschot, Paul C.A Survey and Evaluation Framework for Secure DNS Resolution.